

SIMATS ENGINEERING

ASSESSMENT TOOL 01

COURSE NAME: Ethical Hacking

COURSE CODE: ITA1408

COURSE OUTCOME COVERED

***CO4:** Carry out network security testing techniques that involve attacking web servers, analyzing vulnerabilities in web applications, and evaluating wireless network security with the help of Kali Linux.*

QUESTIONS: 01

Total Marks:100

Annexure A

SECURITY TESTING SIMULATION TASK

Code of Conduct:

I J Sravani (192372141)(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: J Sravani

S.No.	Assessment Criterion	Excellent	Good	Satisfactory	Needs Improvement	Marks
1	Tool Selection and Configuration(20)	Selects appropriate open-source tools, configures them correctly, and clearly explains the purpose of each tool.	Selects suitable tools and configures them with minor errors or limited explanation.	Uses basic tools with partial configuration and limited understanding.	Selects inappropriate tools or fails to configure them correctly.	
2	Testing Procedure and Execution(20)	Follows a systematic, authorized, safe, and well-documented testing procedure within the approved scope.	Performs the major testing steps correctly with minor omissions.	Completes only basic testing steps with limited documentation.	Testing procedure is incomplete, unsafe, unauthorized, or poorly executed.	
3	Identification and Validation of Vulnerabilities(20)	Accurately identifies vulnerabilities, manually validates findings, and distinguishes confirmed issues from false positives.	Identifies and validates most important findings with minor gaps.	Identifies basic vulnerabilities but provides limited validation.	Findings are inaccurate, unsupported, or based only on automated tool output.	
4	Risk Analysis and Remediation(20)	Clearly explains the cause, likelihood, impact, severity, and practical remediation for every confirmed vulnerability.	Provides suitable risk analysis and recommendations with minor omissions.	Provides general risk descriptions and basic remediation measures.	Risk ratings are unsupported or recommendations are impractical or unrelated.	
5	Evidence, Report Quality, and Ethical Compliance(20)	Provides clear commands, screenshots, outputs, tables, references, and a professional report while maintaining authorization, confidentiality, and ethical conduct.	Provides sufficient evidence and a well-organized report with minor presentation issues.	Provides limited evidence or an adequately organized report.	Evidence is missing, the report is unclear, or ethical and legal requirements are ignored.	
					Total	

Annexure A

NOTE:

- Any testing performed outside the faculty-approved laboratory target, authorized scope, or permitted time must be treated as a serious violation. Destructive testing, denial-of-service activities, unauthorized password attacks, data modification, and testing of public or third-party systems are strictly prohibited.
- **Use any Suitable Open-Source Tool**

Question 1: Web Server Reconnaissance and Vulnerability Analysis

A cybersecurity analyst is assigned an authorized and isolated vulnerable web server for a security assessment. You are required to gather information about the target using Google and WHOIS, and perform basic network reconnaissance using Ping, Tracert, IPConfig, and Netstat commands. Use Nmap to identify open ports, running services, and service versions. Use WhatWeb to identify the web technologies and frameworks used by the server. Examine HTTP response headers using Curl/Wget and identify information disclosure. Perform CGI and web-server vulnerability scanning using Nikto, and use Gobuster/Dirb to discover hidden directories and files. Analyze the identified administrative pages, backup files, configuration files, and vulnerable resources. Finally, classify the findings based on severity and impact, and recommend appropriate web-server hardening and information-disclosure prevention measures. Submit the commands executed, screenshots, observations, findings, and recommendations.

Aim : To carry out a foundational security review of an authorized web server by collecting network details, enumerating open ports and running services, fingerprinting web technologies, inspecting HTTP headers, scanning for weaknesses, and uncovering hidden directories and files.

Target :

- a. **Target IP:** 192.168.56.102
- b. **Target:** Metasploitable 2

Tools Used : Ping, Traceroute, Netstat, Nmap, WhatWeb, Curl, Wget, Nikto, Gobuster and Dirb.

Procedure and Commands

1. Network Reconnaissance :

- a. `ping -c 4 192.168.56.102`
 - b. `tracert 192.168.56.102`
 - c. `netstat -tuln`
- Ping verified that the target host was reachable, showing no packet loss. Traceroute helped trace the network path leading to the target, while Netstat listed the active listening connections on the system.

2. Port and Service Identification :

- a. `nmap 192.168.56.102`
 - b. `nmap -sV 192.168.56.102`
- The Nmap scan enumerated the open ports and services running on the target. Ports 135, 139, and 445 were found open, corresponding to MSRPC, NetBIOS, and Microsoft-DS/SMB services respectively.

3. Web Technology Identification : `whatweb http://192.168.56.102`

- WhatWeb fingerprinted the server as running Apache 2.2.8 on Ubuntu Linux with PHP 5.2.4, and also flagged WebDAV support. The web page responded with an HTTP 200 OK status.

4. HTTP Header Analysis :

- a. `curl -I http://192.168.56.102`
 - b. `wget --server-response --spider http://192.168.56.102`
- The captured HTTP response exposed details such as the Apache version, the underlying Ubuntu platform, and the PHP version in use — information disclosure of this kind can aid an attacker in fingerprinting the server.

5. Web Vulnerability Scanning : `nikto -h http://192.168.56.102`

- Nikto was run to flag typical web-server misconfigurations, outdated components, exposed resources, and other possible security concerns.

6. Directory and File Discovery :

- gobuster dir -u http://192.168.56.102 -w /usr/share/wordlists/dirb/common.txt
 - dirb http://192.168.56.102
- Gobuster and Dirb were used to brute-force and uncover directories and files reachable on the server that were not linked from the main page.

Observations :

- The target host responded successfully to requests from the Kali Linux machine.
- Multiple network services were found running and exposed on the target.
- The specific Apache and PHP version numbers were disclosed by the server.
- WebDAV functionality was detected as enabled on the server.
- The HTTP response headers leaked details about the underlying server technology stack.

Findings and Severity :

Finding	Severity
Server/PHP version disclosure	Low
Outdated Apache/PHP versions	High
WebDAV exposure	Medium
Exposed directories/resources	Medium
Unnecessary network services	Medium

Recommendations

- Update the Apache and PHP installations to their latest supported versions.
- Suppress unnecessary version banners for the server and any frameworks in use.
- Turn off WebDAV support unless it is genuinely needed.
- Decommission unused services and close any ports that are not required.
- Apply suitable HTTP security headers to the web server.

- Carry out periodic vulnerability scans and ongoing server-hardening reviews.

```

[+] Session Actions Edit View Help

zsh: corrupt history file /home/kali/.zsh_history
~
[+] kali@kali:~$
[+] # add
1: lo <BROADCAST,UP,LOWER_UP> 0:00:00:00:00:00 bnd 00:00:00:00:00:00
Link/loopback 00:00:00:00:00:00 bnd 00:00:00:00:00:00
inet 127.0.0.1 u/s scope host lo
valid_lft forever preferred_lft forever
inet6 ::1::128 scope host noprefixroute
valid_lft forever preferred_lft forever
2: eth0 <BROADCAST,MULTICAST,UP,LOWER_UP> 0:00:00:00:00:00 scope group default qlen 1000
Link/ether 00:00:27:43:b0:05 bnd ffff:ffff:ffff:ffff
inet 192.168.56.128 bnd 192.168.56.128 scope global dynamic noprefixroute eth0
valid_lft 4294967295sec preferred_lft 4294967295sec
inet6 fe80::2743:b0:05:7f6a scope Link noprefixroute
valid_lft forever preferred_lft forever
3: eth1 <BROADCAST,MULTICAST,UP,LOWER_UP> 0:00:00:00:00:00 scope group default qlen 1000
Link/ether 00:00:27:43:b0:05 bnd ffff:ffff:ffff:ffff
inet 192.168.56.129 bnd 192.168.56.129 scope global dynamic noprefixroute eth1
valid_lft 5282sec preferred_lft 5282sec
inet6 fe80::2743:b0:05:7f6a scope Link noprefixroute
valid_lft forever preferred_lft forever
4: docke0 <NO-CARRIER,MULTICAST,UP> 0:00:00:00:00:00 scope group default
Link/ether 00:00:27:43:b0:05 bnd ffff:ffff:ffff:ffff
inet 192.17.0.15 bnd 192.17.0.15 scope global dockers
valid_lft forever preferred_lft forever

[+] kali@kali:~$
[+] # ping -c 5 192.168.56.102
PING 192.168.56.102 (192.168.56.102) 56(64) bytes of data.
64 bytes from 192.168.56.102: icmp_seq=1 ttl=128 time=2.82 ms
64 bytes from 192.168.56.102: icmp_seq=2 ttl=128 time=0.713 ms
64 bytes from 192.168.56.102: icmp_seq=3 ttl=128 time=1.17 ms
64 bytes from 192.168.56.102: icmp_seq=4 ttl=128 time=0.722 ms

192.168.56.102 ping statistics =
  5 packets transmitted, 5 received, 0% packet loss, time 3805ms
rtt min/avg/max/mdev = 0.713/1.357/2.826/0.866 ms

[+] kali@kali:~$
[+] # traceroute 192.168.56.102
traceroute to 192.168.56.102 (192.168.56.102), 30 hops max, 68 byte packets
 1  *
 2  *
 3  *
 4  *
 5  *
 6  *
 7  *
 8  *
 9  *

```

```

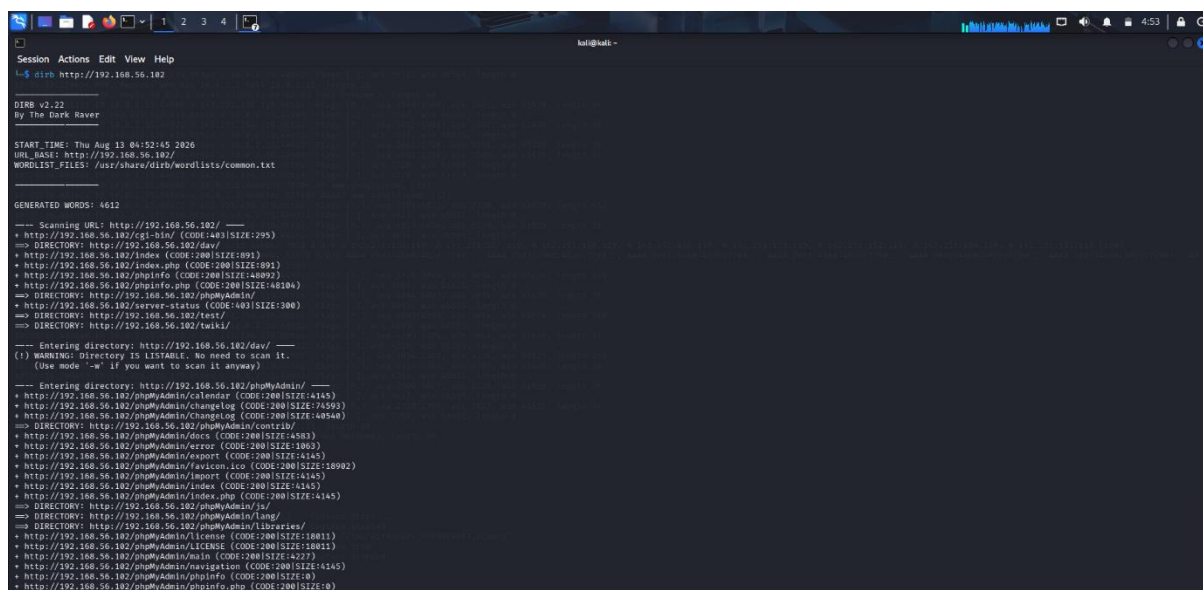
kali@kali:~$ traceroute 192.168.56.102
traceroute to 192.168.56.102 (192.168.56.102), 30 hops max, 60 byte packets
 1  * * *
 2  * * *
 3  * * *
 4  * * *
 5  * * *
 6  * * *
 7  * * *
 8  * * *
 9  * * *
10  * * *
11  * * *
12  * * *
13  * * *
14  * * *
15  * * *
16  * * *
17  * * *
18  * * *
19  * * *
20  * * *
21  * * *
22  * * *
23  * * *
24  * * *
25  * * *
26  * * *
27  * * *
28  * * *
29  * * *
30  * * *

kali@kali:~$ netstat -tln
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
tcp        0      0 0.0.0.0:80               0.0.0.0:*               LISTEN
tcp6       0      0 0.0.0.0:443              0.0.0.0:*               LISTEN

kali@kali:~$ ss -tln
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-13 04:11 EDT
Nmap scan report for 192.168.56.102
Host is up (0.000000s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp   open  mapi
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds

```

[illegible][illegible]



```
Session Actions Edit View Help
$ dirb http://192.168.56.102

DIRB v2.22
By The Dark Raver

START TIME: Thu Aug 13 04:52:45 2020
URL_BASE: http://192.168.56.102/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

--- Scanning URL: http://192.168.56.102/ ---
* http://192.168.56.102/cgi-bin/ (CODE:403|SIZE:295)
=> DIRECTORY: http://192.168.56.102/dav/
* http://192.168.56.102/index (CODE:200|SIZE:3893)
* http://192.168.56.102/index.php (CODE:200|SIZE:3893)
* http://192.168.56.102/phpinfo (CODE:200|SIZE:48092)
* http://192.168.56.102/phpinfo.php (CODE:200|SIZE:48104)
=> DIRECTORY: http://192.168.56.102/phpMyAdmin/
* http://192.168.56.102/server-status (CODE:403|SIZE:300)
=> DIRECTORY: http://192.168.56.102/rest/
=> DIRECTORY: http://192.168.56.102/twiki/

--- Entering directory: http://192.168.56.102/dav/ ---
(!) WARNING: Directory is LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.56.102/phpMyAdmin/ ---
* http://192.168.56.102/phpMyAdmin/calendar (CODE:200|SIZE:4145)
* http://192.168.56.102/phpMyAdmin/changelog (CODE:200|SIZE:74593)
=> DIRECTORY: http://192.168.56.102/phpMyAdmin/contrib/
* http://192.168.56.102/phpMyAdmin/docs (CODE:200|SIZE:4583)
* http://192.168.56.102/phpMyAdmin/error (CODE:200|SIZE:3803)
* http://192.168.56.102/phpMyAdmin/export (CODE:200|SIZE:4145)
* http://192.168.56.102/phpMyAdmin/favicon.ico (CODE:200|SIZE:18992)
* http://192.168.56.102/phpMyAdmin/import (CODE:200|SIZE:4145)
* http://192.168.56.102/phpMyAdmin/index (CODE:200|SIZE:4145)
* http://192.168.56.102/phpMyAdmin/index.php (CODE:200|SIZE:4145)
=> DIRECTORY: http://192.168.56.102/phpMyAdmin/js/
=> DIRECTORY: http://192.168.56.102/phpMyAdmin/lang/
=> DIRECTORY: http://192.168.56.102/phpMyAdmin/libraries/
* http://192.168.56.102/phpMyAdmin/license (CODE:200|SIZE:18011)
* http://192.168.56.102/phpMyAdmin/LICENCE (CODE:200|SIZE:18011)
* http://192.168.56.102/phpMyAdmin/main (CODE:200|SIZE:4227)
* http://192.168.56.102/phpMyAdmin/navigation (CODE:200|SIZE:4145)
* http://192.168.56.102/phpMyAdmin/phpinfo (CODE:200|SIZE:8)
* http://192.168.56.102/phpMyAdmin/phpinfo.php (CODE:200|SIZE:8)
```

Question 2: Web Application Vulnerability Assessment

A cybersecurity analyst is assigned an authorized vulnerable web application in an isolated laboratory environment for security testing. You are required to identify the application's technologies and attack surface using appropriate reconnaissance techniques, examine input fields, parameters, cookies, sessions, and HTTP requests, and use suitable tools to identify vulnerabilities such as SQL Injection, Cross-Site Scripting (XSS), insecure authentication, session-management weaknesses, directory traversal, and security misconfigurations. Use tools such as Burp Suite, OWASP ZAP, Nikto, Nmap, Curl, and browser developer tools to analyze the application. Test the identified vulnerabilities only within the authorized laboratory environment, document the evidence and potential impact of each finding, classify the vulnerabilities according to severity, and recommend appropriate remediation and secure coding practices. Submit the commands/tool configurations, screenshots, observations, vulnerability findings, severity ratings, impacts, and recommendations.

Aim: To carry out a vulnerability assessment of an authorized web application in a controlled lab setting, using Nmap, Nikto, Burp Suite, and OWASP ZAP.

- **Target and Tools :** 192.168.56.102
- Application: Damn Vulnerable Web Application (DVWA)
- Operating System: Metasploitable 2 / Linux
- Tools Used: Nmap, WhatWeb, Nikto, Burp Suite, OWASP ZAP

1. Network and Service Identification

- ping -c 4 192.168.56.102
- nmap -sV -sC 192.168.56.102

```
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history

[kali@kali:~]$ ping -c 4 192.168.56.102
PING 192.168.56.102 (192.168.56.102) 56(84) bytes of data:
64 bytes from 192.168.56.102: icmp_seq=1 ttl=64 time=9.28 ms
64 bytes from 192.168.56.102: icmp_seq=2 ttl=64 time=1.78 ms
64 bytes from 192.168.56.102: icmp_seq=3 ttl=64 time=1.59 ms
64 bytes from 192.168.56.102: icmp_seq=4 ttl=64 time=12.1 ms

--- 192.168.56.102 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3809ms
rtt min/avg/max/mdev = 1.589/6.154/12.053/4.616 ms

[kali@kali:~]$ nmap -v -sC 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-13 05:01 EDT
Nmap scan report for 192.168.56.102
Host is up (0.00077s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE        VERSION
135/tcp    open  msrpc           Microsoft Windows RPC
139/tcp    open  netbios-ssn     Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds?   Microsoft Windows
MAC Address: 0A:00:27:00:00:0A (Unknown)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ nbstat: NetBIOS name: JAMNAVI, NetBIOS user: <unknown>, NetBIOS MAC: 0a:00:27:00:00:0a (unknown)
|_ smb2-security-mode:
|   31bit:
|     Message signing enabled but not required
|_ smb2-time:
|   date: 2026-08-13T09:01:28
|   start_date: N/A

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 53.78 seconds

[kali@kali:~]$ curl -I http://192.168.56.102
HTTP/1.1 200 OK
Date: Thu, 13 Aug 2026 09:03:07 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Content-Type: text/html

[kali@kali:~]$ whatweb http://192.168.56.102
http://192.168.56.102 [200 OK] Apache[2.2.8], Country[RESERVED][22], HTTPServer[Ubuntu LInux][Apache/2.2.8 (Ubuntu) DAV/2], IP[192.168.56.102], PHP[5.2.4-2ubuntu5.10], Title[Metasploitable2 - Linux], WebDAV[2], X-Powered-By[PHP/5.2.4-2ubuntu5.10]
```

2. Web Technology Identification

- `curl -I http://192.168.56.102`
- `whatweb http://192.168.56.102`

```
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history

[kali@kali:~]$ ping -c 4 192.168.56.102
PING 192.168.56.102 (192.168.56.102) 56(84) bytes of data:
64 bytes from 192.168.56.102: icmp_seq=1 ttl=64 time=9.28 ms
64 bytes from 192.168.56.102: icmp_seq=2 ttl=64 time=1.78 ms
64 bytes from 192.168.56.102: icmp_seq=3 ttl=64 time=1.59 ms
64 bytes from 192.168.56.102: icmp_seq=4 ttl=64 time=12.1 ms

--- 192.168.56.102 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3809ms
rtt min/avg/max/mdev = 1.589/6.154/12.053/4.616 ms

[kali@kali:~]$ nmap -v -sC 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-13 05:01 EDT
Nmap scan report for 192.168.56.102
Host is up (0.00077s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE        VERSION
135/tcp    open  msrpc           Microsoft Windows RPC
139/tcp    open  netbios-ssn     Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds?   Microsoft Windows
MAC Address: 0A:00:27:00:00:0A (Unknown)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ nbstat: NetBIOS name: JAMNAVI, NetBIOS user: <unknown>, NetBIOS MAC: 0a:00:27:00:00:0a (unknown)
|_ smb2-security-mode:
|   31bit:
|     Message signing enabled but not required
|_ smb2-time:
|   date: 2026-08-13T09:01:28
|   start_date: N/A

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 53.78 seconds

[kali@kali:~]$ curl -I http://192.168.56.102
HTTP/1.1 200 OK
Date: Thu, 13 Aug 2026 09:03:07 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Content-Type: text/html

[kali@kali:~]$
```

Metasploitable2 - Linux
Warning: Never expose this VM to an untrusted network!
Contact: msfdev[at]metasploit.com
Login with msfadmin/msfadmin to get started

- TWiki
- phpMyAdmin
- Metasploit
- DVWA
- WebDAV

3. Nikto Web Server Scan

- `nikto -h http://192.168.56.102`

```
Session Actions Edit View Help

[kali@kali:~]$ curl http://192.168.56.102
HTTP/2.0 200 OK [Apache/2.2.8 (Ubuntu)] [PHP/5.2.4-2ubuntu5.10]
Title: [Metasploitable2 - Linux]
WebDAV/2, X-Powered-By: PHP/5.2.4-2ubuntu5.10

[kali@kali:~]$ curl -H http://192.168.56.102
Nikto v2.5.0

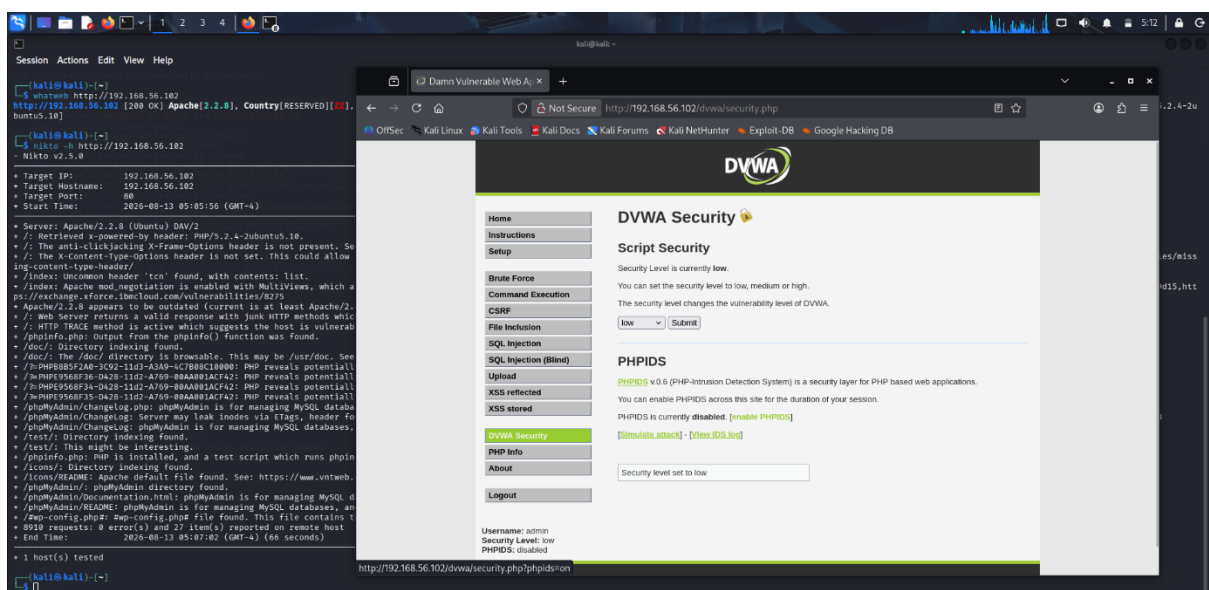
+ Target IP: 192.168.56.102
+ Target Hostname: 192.168.56.102
+ Target Port: 80
+ Start Time: 2020-08-13 05:05:56 (GMT-4)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698bdc59d15.htm
+ /exchange.force.indexcloud.com/vulnerabilities/0295
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /: Web Server returns a valid response with Junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ /PHPBB5F2M-3C92-11d3-A3A9-1C7B8C1A0000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /PHPBB5F2M-3C92-11d3-A3A9-1C7B8C1A0000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /PHPBB5F2M-3C92-11d3-A3A9-1C7B8C1A0000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /PHPBB5F2M-3C92-11d3-A3A9-1C7B8C1A0000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/changelog.php: Server may leak indexes via flags, header found with file /phpMyAdmin/changelog. Inode: 92462, size: 40540, mtime: Tue Dec 9 12:24:00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-icons/README/
+ /phpMyAdmin/: phpMyAdmin directory found.
+ /phpMyAdmin/documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ /zoo-config.php: zoo-config.php file found. This file contains the credentials.
+ 8918 requests: 0 error(s) and 27 item(s) reported on remote host
+ End Time: 2020-08-13 05:07:00 (GMT-4) (60 seconds)

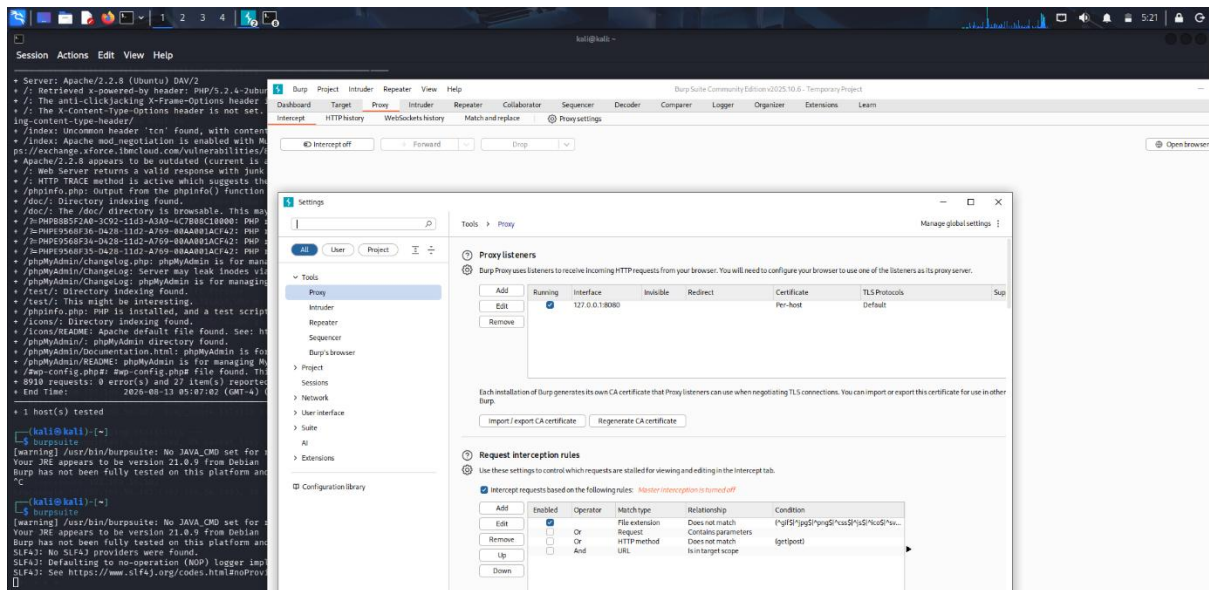
+ 1 host(s) tested

[kali@kali:~]$
```

4. DVWA Security Configuration : The security level was configured to Low for controlled laboratory testing.

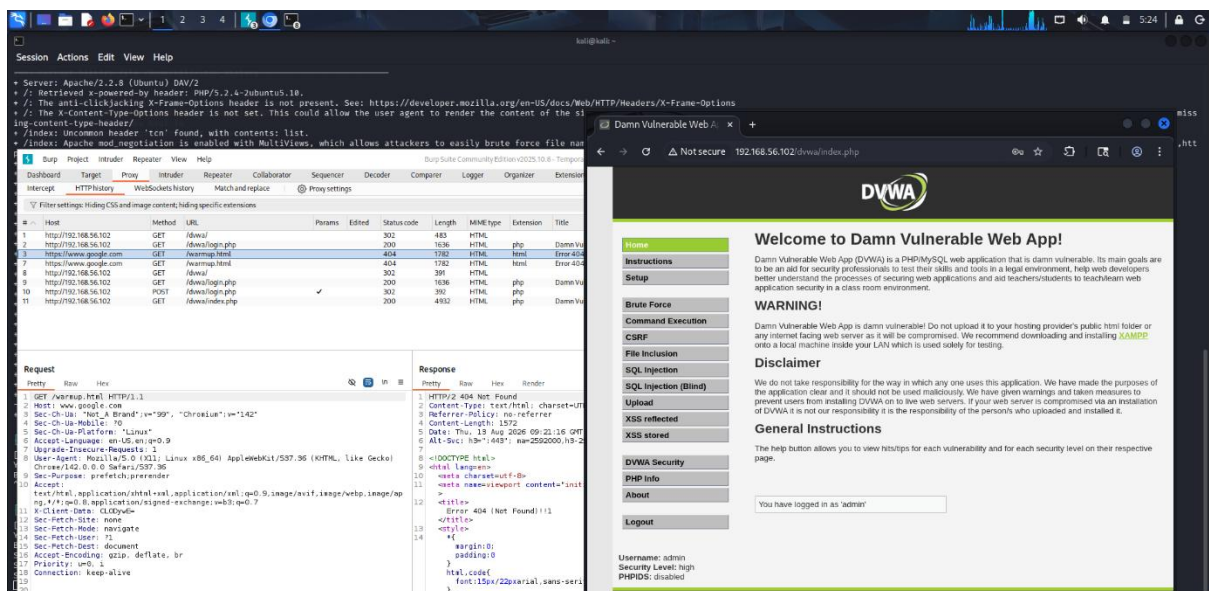


5. Burp Suite Proxy Configuration : The Burp Proxy listener was configured on 127.0.0.1:8080



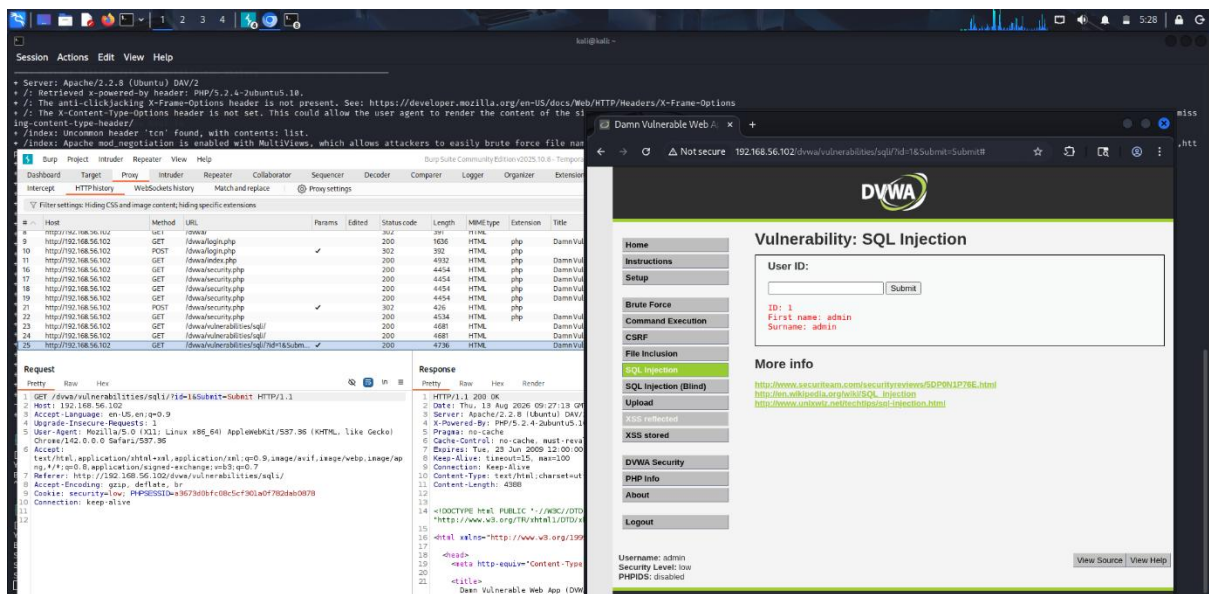
6. Burp Suite HTTP History

- Requests generated while browsing DVWA were captured in the Burp Suite HTTP History tab.
- Both GET and POST requests were visible in the captured traffic.
- Login attempts and other application requests were logged for review.



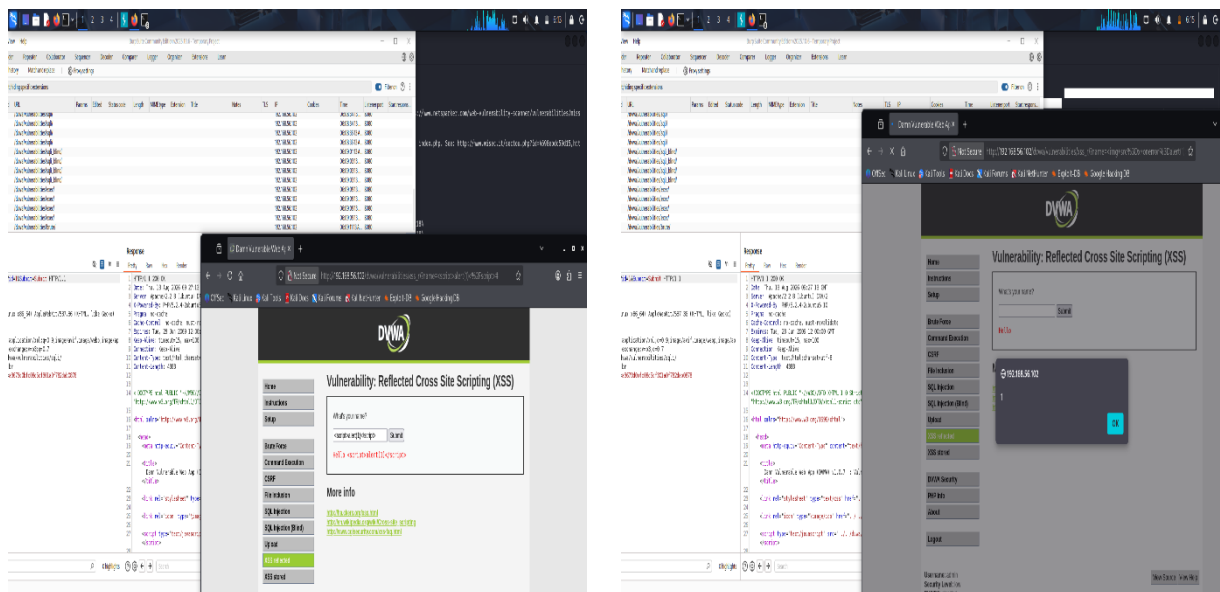
7. SQL Injection Testing

- The SQL Injection module within DVWA was opened for testing.
- A value was submitted through the id parameter.
- Burp Suite was used to intercept and capture the resulting request.



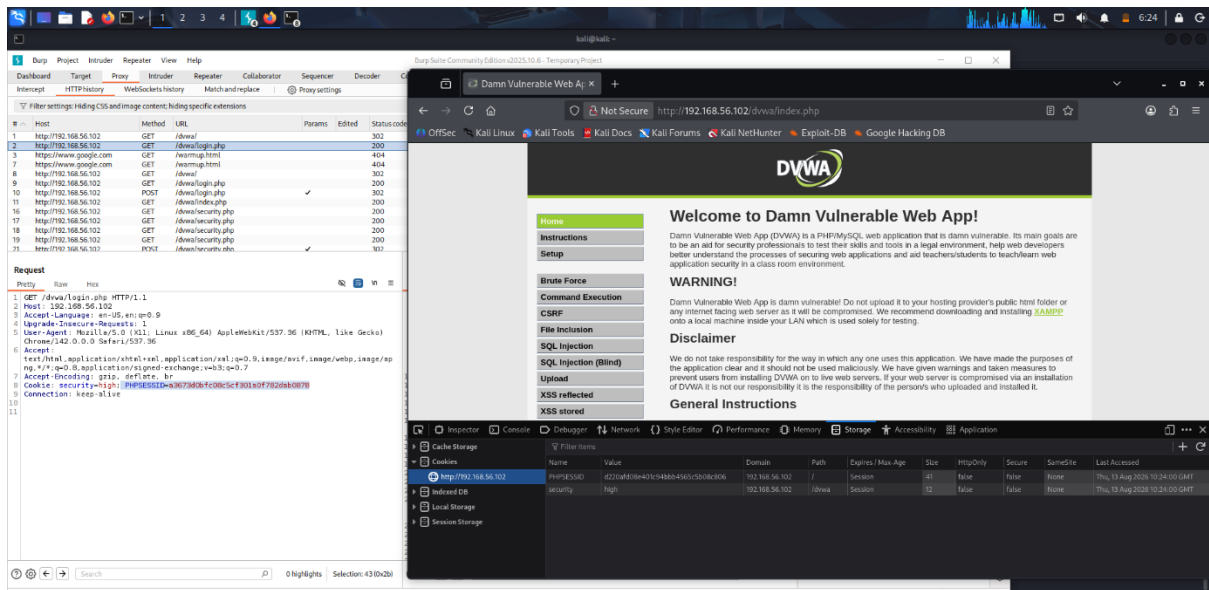
8. Reflected Cross-Site Scripting (XSS)

- The Reflected XSS module in DVWA was accessed for testing.
- A sample JavaScript payload was entered and submitted as test input.



9. Session Cookie Analysis

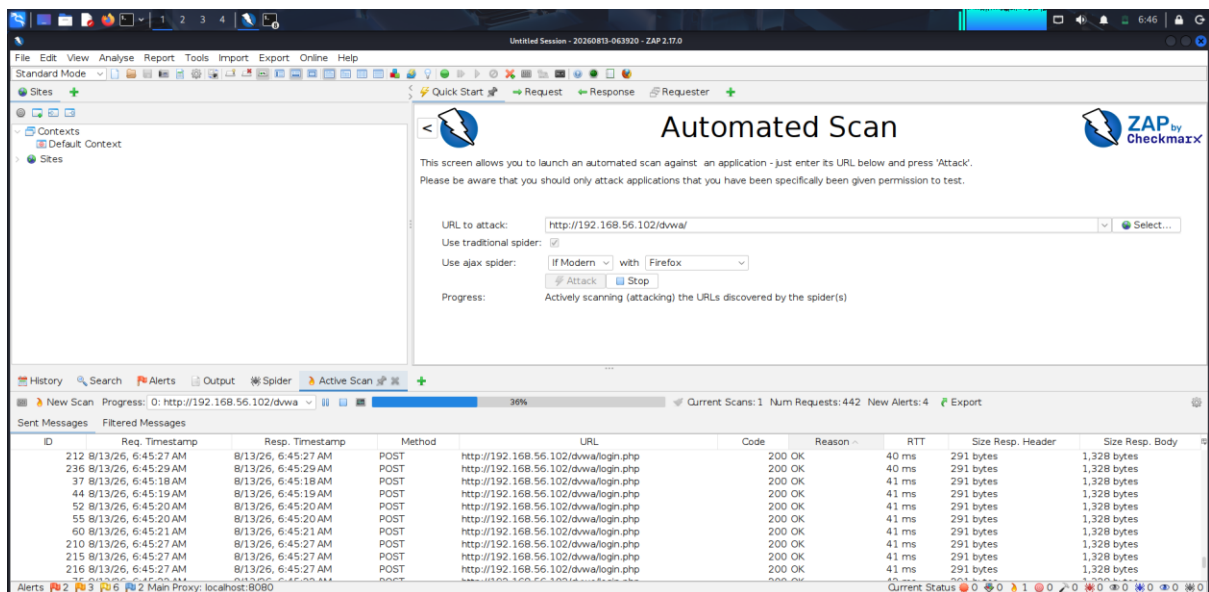
- The browser's Developer Tools were used to examine the cookies set by the application.
- The PHPSESSID session cookie was located among the stored cookies.
- The security-related attributes of the cookie were reviewed.



10. OWASP ZAP Automated Scan

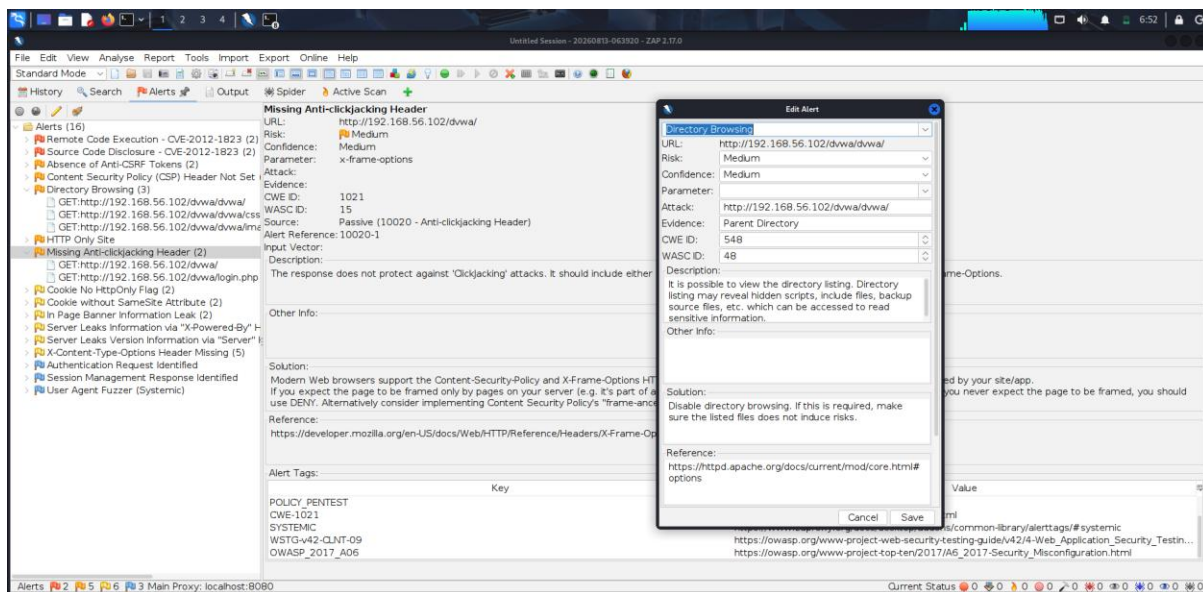
Target : <http://192.168.56.102/dvwa/>

- The scan generated a total of 442 requests.
- At that point, 4 new alerts had been raised by the scanner.



11. OWASP ZAP Security Findings :

- Directory browsing was found to be enabled.
- The anti-clickjacking header was missing.
- Anti-CSRF tokens were not present.
- No Content Security Policy header had been configured.



12. Conclusion :

The vulnerability assessment was completed successfully within the controlled DVWA/Metasploitable lab setup. The overall results highlight how important it is to maintain secure server configuration, enforce input validation, apply HTTP security headers, protect session cookies, and run automated vulnerability scans on a regular basis.

Question 3: Security Header and HTTPS Configuration Assessment

A cybersecurity analyst is assigned an authorized web application hosted in an isolated laboratory environment to assess its HTTPS and security-header configuration. You are required to use Curl to examine HTTP response headers and Nmap SSL scripts to analyze the server's HTTPS/TLS configuration. Identify missing or improperly configured security headers such as Content-Security-Policy (CSP), HSTS, X-Frame-Options, and X-Content-Type-Options, and verify whether HTTP requests are automatically redirected to HTTPS. Examine the TLS configuration for weak protocols, insecure cipher suites, and certificate-related issues. Analyze the security purpose and potential impact of each misconfiguration, classify the findings according to their severity, and recommend appropriate HTTPS, TLS, certificate, and security-header hardening measures. Submit the commands used, screenshots, observations, identified risks, severity classification, and remediation recommendations.

Aim : To assess the HTTPS, TLS, certificate, and HTTP security-header setup of the target using Curl and Nmap.

Target: 192.168.56.102 (Metasploitable 2)

Tools: Curl, Nmap

Commands Used :

- `curl -I http://192.168.56.102`
- `curl -k -I https://192.168.56.102`
- `curl -I http://192.168.56.102:443`
- `nmap -Pn -p 443 --script ssl-enum-ciphers 192.168.56.102`
- `nmap -Pn -p 443 --script ssl-cert 192.168.56.102`

Practical Observations :

The plain HTTP request returned a 200 OK response, and no redirection to HTTPS took place. Attempting the request over HTTPS failed with a wrong-version-number error. Sending an HTTP request to port 443 also returned 200 OK, which suggests that port 443 was serving plain HTTP rather than negotiating TLS correctly. Nmap confirmed port 443 was open, but it was unable to enumerate the TLS cipher suites or retrieve certificate details.

Findings and Severity

- Missing HTTP-to-HTTPS redirection : Medium
- Missing CSP, HSTS, X-Frame-Options and X-Content-Type-Options : Medium/Low
- Improper HTTPS/TLS configuration on port 443 : High

Remediation

Set up Apache to properly serve HTTPS over port 443, install valid TLS certificates, enforce a redirect from HTTP to HTTPS, disable outdated TLS protocol versions, adopt strong cipher suites, and implement CSP, HSTS, X-Frame-Options, and X-Content-Type-Options headers.

Result

The assessment of the web server's HTTPS and security-header configuration was completed successfully. It surfaced several hardening gaps along with an incorrectly configured HTTPS service.

```
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
[kali@kali]~$ curl -k -I https://192.168.56.102
curl: (35) TLS connect error: error:0A00010B:SSL routines::wrong version number

[kali@kali]~$ curl -I http://192.168.56.102:443
HTTP/1.1 200 OK
Date: Thu, 13 Aug 2026 12:13:11 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2 mod_ssl/2.2.8 OpenSSL/0.9.8g
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Content-Type: text/html

[kali@kali]~$ ssh -o HostKeyAlgorithms=ssh-rsa -o PubkeyAcceptedAlgorithms=ssh-rsa msfadmin@192.168.56.102
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pg.html
msfadmin@192.168.56.102's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Thu Aug 13 07:39:32 2026 from 192.168.56.101
msfadmin@metasploitable:~$ sudo grep -n "Listen" /etc/apache2/ports.conf
1:listen 0.0.0.0:80
4: listen 0.0.0.0:443
msfadmin@metasploitable:~$ sudo grep -n "Listen" /etc/apache2/ports.conf
1:listen 0.0.0.0:80
4: listen 0.0.0.0:443
msfadmin@metasploitable:~$ sudo grep -nE 'VirtualHost|SSLEngine|SSLCertificate' /etc/apache2/sites-available/ssl-site
1:NameVirtualHost *
2:<VirtualHost *
60:</VirtualHost>
61: SSLEngine on
62: SSLCertificateFile /etc/apache2/ssl/server.crt
63: SSLCertificateKeyFile /etc/apache2/ssl/server.key
64: /etc/apache2/sites-available/ssl-site
msfadmin@metasploitable:~$ sudo /etc/init.d/apache2 restart
* Restarting web server apache2
[Thu Aug 13 08:16:58 2026] [error] VirtualHost *:443 -- mixing * ports and non-* ports with a NameVirtualHost address is not supported, proceeding with undefined results
[Thu Aug 13 08:16:58 2026] [warn] NameVirtualHost *:8 has no VirtualHosts
[Thu Aug 13 08:17:08 2026] [error] VirtualHost *:443 -- mixing * ports and non-* ports with a NameVirtualHost address is not supported, proceeding with undefined results
[Thu Aug 13 08:17:08 2026] [warn] NameVirtualHost *:8 has no VirtualHosts
...done.
msfadmin@metasploitable:~$ exit
```

```
msfadmin@metasploitable:~$ sudo grep -n "Listen" /etc/apache2/ports.conf
1:listen 0.0.0.0:80
4: listen 0.0.0.0:443
msfadmin@metasploitable:~$ sudo grep -n "Listen" /etc/apache2/ports.conf
1:listen 0.0.0.0:80
4: listen 0.0.0.0:443
msfadmin@metasploitable:~$ sudo grep -nE 'VirtualHost|SSLEngine|SSLCertificate' /etc/apache2/sites-available/ssl-site
1:NameVirtualHost *
2:<VirtualHost *
60:</VirtualHost>
61: SSLEngine on
62: SSLCertificateFile /etc/apache2/ssl/server.crt
63: SSLCertificateKeyFile /etc/apache2/ssl/server.key
64: /etc/apache2/sites-available/ssl-site
msfadmin@metasploitable:~$ sudo /etc/init.d/apache2 restart
* Restarting web server apache2
[Thu Aug 13 08:16:58 2026] [error] VirtualHost *:443 -- mixing * ports and non-* ports with a NameVirtualHost address is not supported, proceeding with undefined results
[Thu Aug 13 08:16:58 2026] [warn] NameVirtualHost *:8 has no VirtualHosts
[Thu Aug 13 08:17:08 2026] [error] VirtualHost *:443 -- mixing * ports and non-* ports with a NameVirtualHost address is not supported, proceeding with undefined results
[Thu Aug 13 08:17:08 2026] [warn] NameVirtualHost *:8 has no VirtualHosts
...done.
msfadmin@metasploitable:~$ exit
logout
Connection to 192.168.56.102 closed.

[kali@kali]~$ curl -k -I https://192.168.56.102
curl: (35) TLS connect error: error:0A00010B:SSL routines::wrong version number

[kali@kali]~$ nmap -p -s 443 --script ssl-enum-ciphers 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-14 00:32 EDT
Nmap scan report for 192.168.56.102
Host is up (0.0015s latency).

PORT      STATE SERVICE
443/tcp   open  https
MAC Address: 08:00:27:73:F8:10 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 25.93 seconds

[kali@kali]~$ nmap -p -s 443 --script ssl-cert 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-14 00:33 EDT
Nmap scan report for 192.168.56.102
Host is up (0.0015s latency).

PORT      STATE SERVICE
443/tcp   open  https
MAC Address: 08:00:27:73:F8:10 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.38 seconds

[kali@kali]~$
```

Question 4: Broken Access-Control Assessment

A cybersecurity analyst is assigned an authorized student portal in an isolated laboratory environment containing separate student and administrator test accounts. Using OWASP ZAP, capture and analyze requests generated while accessing student records and identify test object identifiers in URLs, forms, cookies, or API requests. Using only the test identifiers provided by the faculty, determine whether one student account can access another student's records or whether a normal user can directly access administrator-only resources. Compare the server responses for authorized and unauthorized requests, explain the difference between authentication and authorization failures, classify the identified access-control weaknesses based on their severity and impact, and recommend appropriate server-side authorization checks, role validation, and secure object-reference mechanisms. Submit the testing procedure,

commands/configuration, screenshots, observations, confirmed findings, severity, impact, and remediation measures.

Aim : To use OWASP ZAP to capture and analyze HTTP requests and responses of an authorized vulnerable web application and examine access-control related information.

Tools Used :

- Kali Linux
- OWASP ZAP 2.17.0
- Metasploitable2
- Mutillidae web application

Procedure

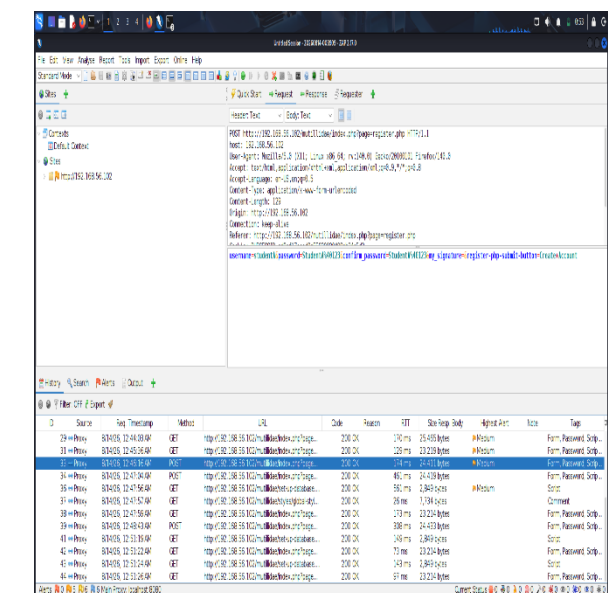
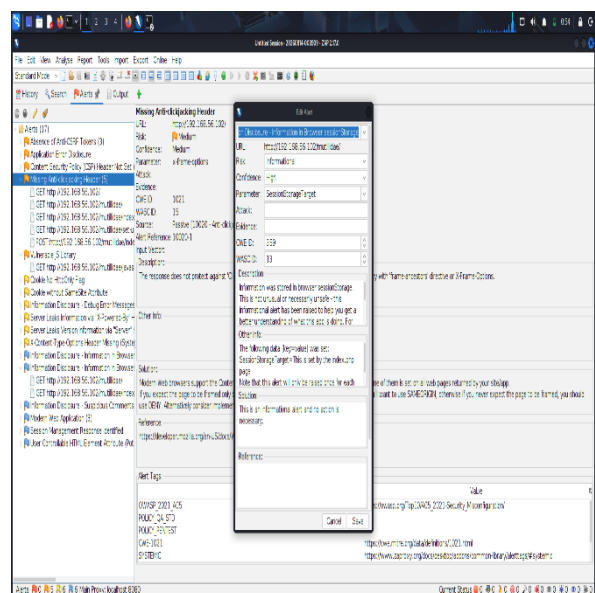
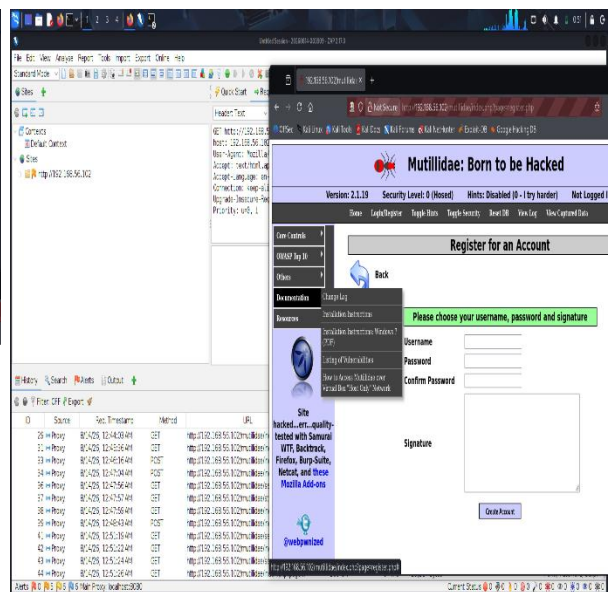
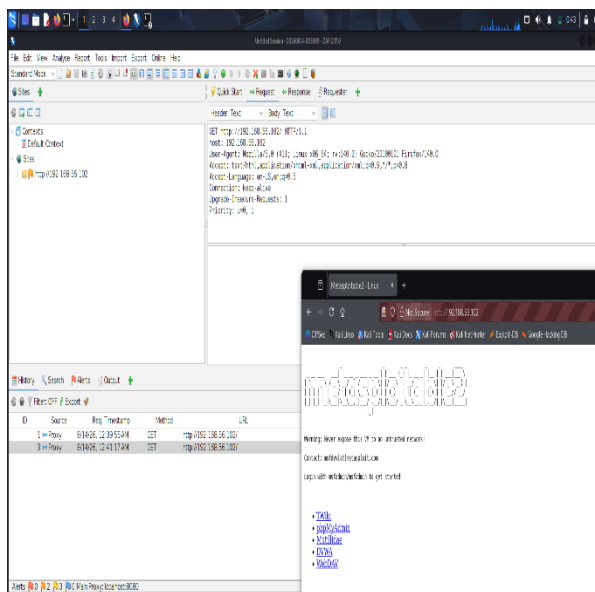
- Launched OWASP ZAP on the Kali Linux machine.
- Set the browser's proxy settings to route traffic through ZAP.
- Browsed to the authorized lab server located at 192.168.56.102.
- Loaded the Mutillidae web application in the browser.
- Clicked through the application's pages while ZAP recorded every HTTP request generated in the background.
- Reviewed the captured traffic by opening the History tab in ZAP.
- Studied the request methods, URLs, parameters, cookie/session data, and corresponding HTTP responses.
- Compared request and response details to understand how the application distinguishes between authentication and authorization checks.
- Reviewed the ZAP Alerts tab for issues flagged within the intentionally vulnerable application.

Commands / Configuration

Target: http : //192.168.56.102/

Mutillidae : http://192.168.56.102/mutillidae/

ZAP Proxy: 127.0.0.1:8080



Question 5: Automated Scanning and Manual Validation

A cybersecurity analyst is assigned an authorized web application hosted in a controlled cybersecurity laboratory for vulnerability assessment. Use Nikto to identify web-server misconfigurations and outdated components, and use Wapiti or OWASP ZAP to perform an automated web-application security scan. Compare the vulnerabilities reported by the selected tools and categorize them into misconfiguration, information disclosure, authentication, and injection issues. Select at least three findings for safe manual validation within the authorized laboratory environment and determine whether each finding is confirmed, a false positive, or requires further investigation. Assign an appropriate severity level based on likelihood and

potential impact, and recommend practical remediation measures for all confirmed vulnerabilities. Submit a comparative report containing tool outputs, screenshots, validation evidence, severity classification, remediation measures, and overall conclusions.

Aim : To detect misconfigurations on the web server and vulnerabilities in the web application using Nikto and OWASP ZAP, manually verify a selection of the findings, rate their severity, and propose remediation steps.

Target and Tools

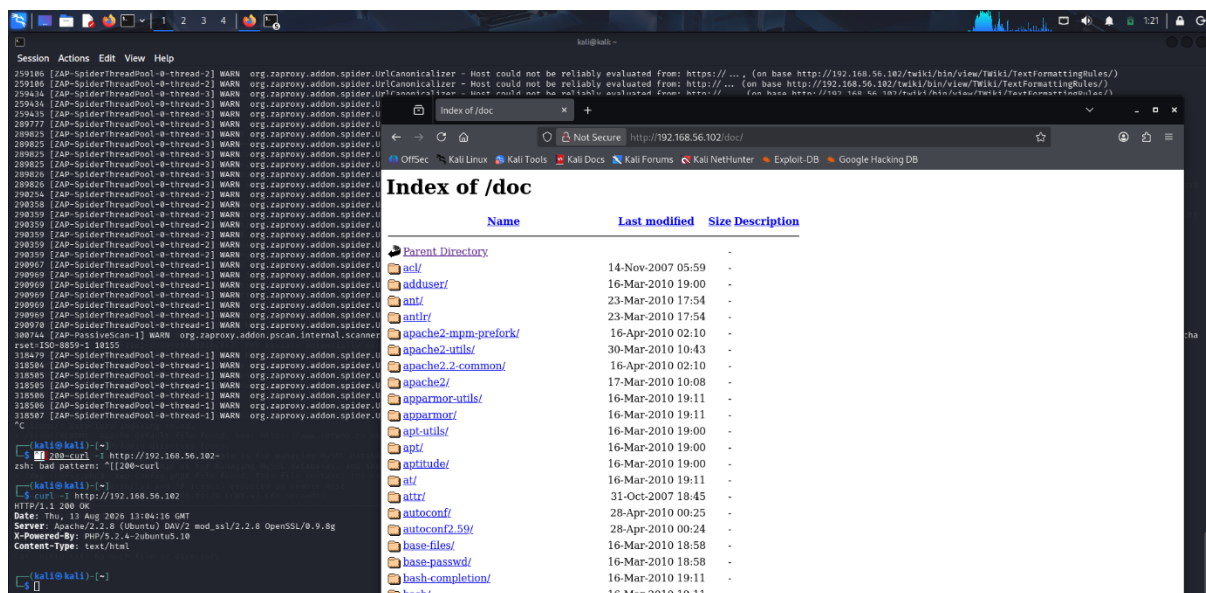
- Target: 192.168.56.102
- Nikto: Web-server vulnerability scanner
- OWASP ZAP 2.17.0: Web-application security scanner
- Browser & curl: Manual validation

Nikto identified:

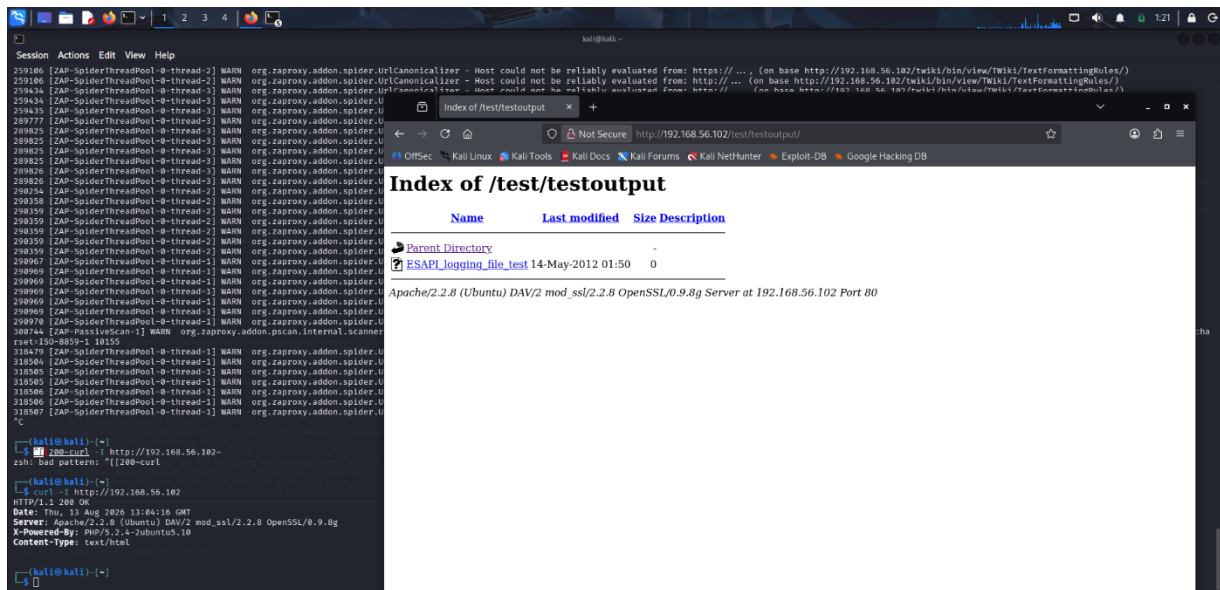
- Outdated Apache/2.2.8 and OpenSSL/0.9.8g components
- Absence of key security headers
- Directory indexing enabled under /doc/, /test/, and /icons/
- Information disclosure via phpinfo.php
- Publicly exposed phpMyAdmin interface
- A number of other server information leaks

5. Manual Validation :

Finding	Validation Evidence	Result	Severity
Missing security headers	Running curl -I against http://192.168.56.102 confirmed that headers such as CSP and X-Frame-Options were absent	Confirmed	Low/Medium
Directory browsing	Browsing to /doc/ showed an "Index of /doc" listing with the full directory contents	Confirmed	Medium
Information disclosure	Nikto flagged phpinfo.php, which was then confirmed by loading it directly in the browser	Confirmed	Medium



- Nikto proved more effective at surfacing server-level issues, whereas ZAP offered wider coverage of web-application and HTTP security concerns. A few issues, including directory browsing and missing security headers, showed up in the results of both tools.



6. Comparison

Tool	Main Purpose	Findings
Nikto	Web-server assessment	Outdated software versions, directory indexing, phpinfo exposure, and general server misconfiguration
OWASP ZAP	Web-application assessment	Missing security headers, information disclosure, cookie issues, directory browsing, and other application-level alerts

